Risk analysis and management for ICT systems

Introduction to risk management methodology, juridical aspects and case studies

Stefano Zatti and Raffaele Gargiulo

DIPARTIMENTO
DI INFORMATICA



SAPIENZA
UNIVERSITÀ DI ROMA

Risk analysis and management (ZATTI)

1. Introduction. The ISO 27000 family of standards
2. The ISO 27005 standard for management of information technology risks
3. Similar standards: NIST 800-30
4. Methodologies: Octave, EBIOS, ...
5. The threat profile from ENISA
6. The implementation of the ISMS - how to start a project - phases of risk assessment
7. Asset inventory and scope definition. Threats and vulnerabilities
8. Risk evaluation, risk treatment, countermeasures, communication
9. Case study: the corporate ICT system
10. Case study: Cyber security of Space Missions

Who is NIST? Focus on USA

- The **National Institute of Standards and Technology (NIST)** is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems in U.S.
- Located in Gaithersburg, Maryland



What does NIST do? Focus on USA

- **NIST Special Publication 800-series General Information**
- Publications in NIST's Special Publication (SP) 800 series present information of interest to the computer security community. The series comprises guidelines, recommendations, technical specifications, and annual reports of NIST's cybersecurity activities.

NIST Special Publication 800-30
Revision 1

Guide for Conducting Risk Assessments



JOINT TASK FORCE
TRANSFORMATION INITIATIVE

INFORMATION SECURITY

Computer Security Division
Information Technology Laboratory
National Institute of Standards and Technology
Gaithersburg, MD 20899-8930

September 2012

About NIST 800-30

Developed by the Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST)

- ITL:
  - promotes the U.S. economy and public welfare by providing technical leadership for the nation's measurement and standards infrastructure.
  - develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology.
- ITL's responsibilities include:
  - the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems

NIST & ISO – An effort to alignment

DEVELOPING COMMON INFORMATION SECURITY FOUNDATIONS

- NIST is working with public and private sector entities to establish specific mappings and relationships between the security standards and guidelines developed by NIST and the International Organization for Standardization and International Electrotechnical Commission (ISO/IEC).

NIST SP 800-30 vs. ISO

- Unlike ISO 27005 and OCTAVE, NIST SP 800-30 cannot be used for organizational risk assessment. There is no asset identification in NIST SP 800-30. As such, it focuses only on a specific infrastructure and its boundaries at a time.
- While ISO 27005 is influenced by NIST SP 800-30, unlike ISO 27005 there is only one way that risk can be calculated under NIST SP 800-30. ISO 27005 allows for different computational methods, while NIST SP 800-30 is highly prescriptive, since the objective is to perform a technical risk analysis of the core IT infrastructure.

NIST SP 800-30
RELATED PUBLICATIONS

- Special Publication 800-39,
  - Managing Information Security Risk: Organization, Mission, and Information System View;
- Special Publication 800-37,
  - Risk Management Framework for Information Systems and Organizations - A System Life Cycle Approach for Security and Privacy;
- Special Publication 800-53 rev 4,
  - Security and Privacy Controls for Federal Information Systems and Organizations; and
- Special Publication 800-53A,
  - Guide for Assessing the Security Controls in Federal Information Systems and Organizations: Building Effective Security Assessment Plans.

NIST 800-30

- The NIST SP 800-30 document is a recommendatory guideline for securing IT infrastructure from a purely technical perspective. NIST SP 800-30 was one of the first risk assessment standards, and most other standards are influenced by it. It has been widely used for Infosec risk assessment globally, and is relevant to any business with an IT component.

Risk assessment and NIST SP 800-30

- NIST SP 800-30 looks specifically at securing the infrastructure on which the data resides. Here, organizational risks or business requirements are not a yardstick for measuring risk, as with ISO 27005 or OCTAVE.

RISK ASSESSMENT

NIST 800-30

- *Organizations employ risk assessments on an **ongoing basis throughout the system development life cycle and across all of the tiers in the risk management hierarchy**—with the frequency of the risk assessments and the resources applied during the assessments, commensurate with the expressly defined purpose and scope of the assessments.*

RISK ASSESSMENT

NIST 800-30

- *Risk assessments **address the potential adverse impacts** to organizational operations and assets, individuals, other organizations, and the economic and national security interests of the United States, **arising from the operation and use of information systems and the information processed, stored, and transmitted by those systems**.*

RISK ASSESSMENT

NIST 800-30

- *Organizations conduct risk assessments to **determine risks** that are common to the organization's core missions/business functions, mission/business processes, mission/business segments, common infrastructure/support services, or information systems.*

RISK ASSESSMENT

NIST 800-30

- *Risk assessments can **support** a wide variety of **risk-based decisions and activities** by organizational officials **across all three tiers** in the risk management hierarchy including, but not limited to, the following (e.g.):*
  - *Development of an information security architecture;*
  - *Definition of interconnection requirements for information systems*
  - *Design of security solutions for information systems and environments of operation*
  - *…*

KEY RISK CONCEPTS

NIST 800-30

Risk *is a measure of the extent to which an entity is threatened by a potential circumstance or event, and is typically a function of:*

- *(i) the adverse impacts that would arise if the circumstance or event occurs; and*
- *(ii) the likelihood of occurrence.*

KEY RISK CONCEPTS

NIST 800-30

Information security risks

are those risks that arise from the loss of confidentiality, integrity, or availability of information or information systems and reflect the potential adverse impacts to organizational operations (i.e., mission, functions, image, or reputation), organizational assets, individuals, other organizations, and the Nation.

KEY RISK CONCEPTS

NIST 800-30

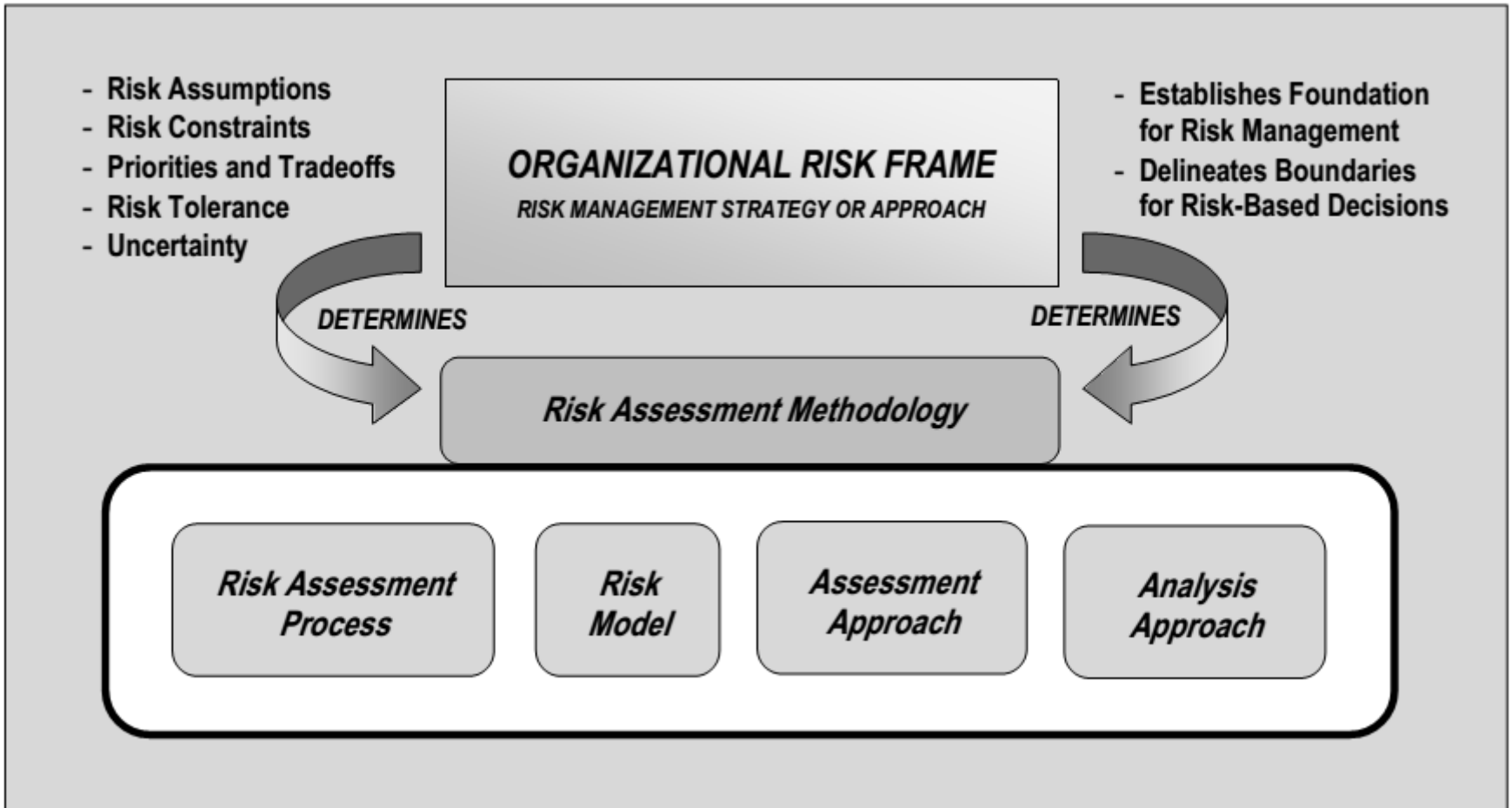
Risk assessment methodology *typically includes:*

- *(i) a **risk assessment process**;*
- *(ii) an **explicit risk model**, defining key terms and assessable risk factors and the relationships among the factors;*
- *(iii) an **assessment approach** (e.g., quantitative, qualitative, or semi-qualitative), specifying the range of values those risk factors can assume during the risk assessment and how combinations of risk factors are identified/analyzed so that values of those factors can be functionally combined to evaluate risk; and*
- *(iv) an **analysis approach** (e.g., threat oriented, asset/impact-oriented, or vulnerability-oriented), describing how combinations of risk factors are identified/analyzed to ensure adequate coverage of the problem space at a consistent level of detail.*

*Risk assessment methodologies are **defined by organizations** and **are a component of the risk management strategy developed during the risk framing** step of the risk management process.*

KEY RISK CONCEPTS

RELATIONSHIP AMONG RISK FRAMING COMPONENTS NIST 800-30



KEY RISK CONCEPTS

NIST 800-30

*Organizations can use a **single risk assessment methodology or can employ multiple assessment methodologies**, with the selection of a specific methodology depending on, for example:*

- *(i) the time frame for investment planning or for planning policy changes;*
- *(ii) the complexity/maturity of organizational mission/business processes (by enterprise architecture segments);*
- *(iii) the phase of the information systems in the system development life cycle; or*
- *(iv) the criticality/sensitivity of the information and information systems supporting the core organizational missions/business functions.*

KEY RISK CONCEPTS

NIST 800-30

*By making explicit the **risk model**, the **assessment approach**, and the **analysis approach employed**, and **requiring as part of the assessment process, a rationale for the assessed values of risk factors**, organizations can increase the reproducibility and repeatability of risk assessments.*

KEY RISK CONCEPTS

NIST 800-30

Reproducibility *refers to the ability of different experts to produce the same results from the same data.*

Repeatability *refers to the ability to repeat the assessment in the future, in a manner that is consistent with and hence comparable to prior assessments—enabling the organization to identify trends.*

KEY RISK CONCEPTS
Risk Models

NIST 800-30

Risk models *define the risk factors to be assessed and the relationships among those factors.*

Risk factors *are characteristics used in risk models as inputs to determining levels of risk in risk assessments.*

Risk factors are also used extensively in risk communications to highlight what strongly affects the levels of risk in particular situations, circumstances, or contexts.

KEY RISK CONCEPTS
Risk Models

NIST 800-30

- *Typical **risk factors include**: threat, vulnerability, impact, likelihood, and predisposing condition.*
- *Risk factors **can be decomposed into more detailed characteristics** (e.g., threats decomposed into threat sources and threat events).*

- *These definitions are **important for organizations to document prior** to conducting risk assessments because the **assessments rely upon well-defined attributes of** threats, vulnerabilities, impact, and other risk factors to effectively determine risk.*

KEY RISK CONCEPTS
Risk Models

NIST 800-30

- ***Threat*** *- any circumstance or event with the potential to adversely impact organizational operations and assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, or modification of information, and/or denial of service.*

- ***Threat events*** *are caused by* ***threat sources****.*

KEY RISK CONCEPTS
Risk Models

NIST 800-30

- *A **threat source** is characterized as:*
  - *(i) the intent and method targeted at the exploitation of a vulnerability; or*
  - *(ii) a situation and method that may accidentally exploit a vulnerability.*

  - *In general, **types of threat sources** include:*
    - *(i) hostile cyber or physical attacks;*
    - *(ii) human errors of omission or commission;*
    - *(iii) structural failures of organization-controlled resources (e.g., hardware, software, environmental controls); and*
    - *(iv) natural and man-made disasters, accidents, and failures beyond the control of the organization.*

SECTION 1

INTRODUCTION

THE NEED FOR RISK ASSESSMENTS TO SUPPORT ENTERPRISE-WIDE RISK MANAGEMENT

THE NEED FOR RISK ASSESSMENTS TO SUPPORT ENTERPRISE-WIDE RISK MANAGEMENT

- Information systems are subject to serious **threats** that can have adverse effects on organizational operations and assets, individuals, other organizations, and the Nation by exploiting both known and unknown **vulnerabilities** to compromise the confidentiality, integrity, or availability of the information being processed, stored, or transmitted by those systems.

THE NEED FOR RISK ASSESSMENTS TO SUPPORT ENTERPRISE-WIDE RISK MANAGEMENT

- Threats to information systems can include:
  - purposeful attacks, environmental disruptions, human/machine errors, and structural failures, and can result in harm to the national and economic security interests of the United States.
  - It is imperative that leaders and managers at all levels understand their responsibilities and are held accountable for managing information security risk—that is,
    - the risk associated with the operation and use of information systems that support the missions and business functions of their organizations.

Risk assessment: what is it and why?

- Risk Assessment is one of the fundamental components of an organizational risk management process as described in **NIST Special Publication 800-39** (*later*)
- Risk assessments are **used to** identify, estimate, and prioritize risk to organizational operations (i.e., mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation and use of information systems.

Risk assessment introduction

- The **purpose of risk assessments** is to inform decision makers and support risk responses by identifying:
  - (i) relevant threats to organizations or threats directed through organizations against other organizations;
  - (ii) vulnerabilities both internal and external to organizations;
  - (iii) impact (i.e., harm) to organizations that may occur given the potential for threats exploiting vulnerabilities; and
  - (iv) likelihood that harm will occur.
- The **end result** is a determination of **risk**
  - i.e., typically a function of the degree of harm and likelihood of harm occurring.

The NIST Risk Management Framework:

- Provides a repeatable process designed to promote the protection of information and information systems commensurate with risk;
- Emphasizes organization-wide preparation necessary to manage security and privacy risks;
- Facilitates the categorization of information and systems, the selection, implementation, assessment, and monitoring of controls, and the authorization of information systems and common controls;
- Promotes the use of automation for near real-time risk management and ongoing system and control authorization through the implementation of continuous monitoring processes;
- Encourages the use of correct and timely metrics to provide senior leaders and managers with the necessary information to make cost-effective, risk-based decisions for information systems supporting their missions and business functions;
- Facilitates the integration of security and privacy requirements and controls into enterprise architecture, acquisition processes, and systems engineering processes;
- Connects risk management processes at the organization and mission/business process levels to risk management processes at the information system level through a senior accountable official for risk management and risk executive (function); and
- Establishes responsibility and accountability for controls implemented within information systems and inherited by those systems.

RISK ASSESSMENT

NIST 800-30

This publication focuses on the *risk assessment* component of risk management—providing a step-by-step process for organizations on:

- (i) how to prepare for risk assessments;
- (ii) how to conduct risk assessments;
- (iii) how to communicate risk assessment results to key organizational personnel; and
- (iv) how to maintain the risk assessments over time.

Risk assessment introduction

Risk assessments can be conducted at all **three tiers** in the risk management hierarchy including: Tier 1 (organization), Tier 2 (business processes) and Tier 3 (information systems)

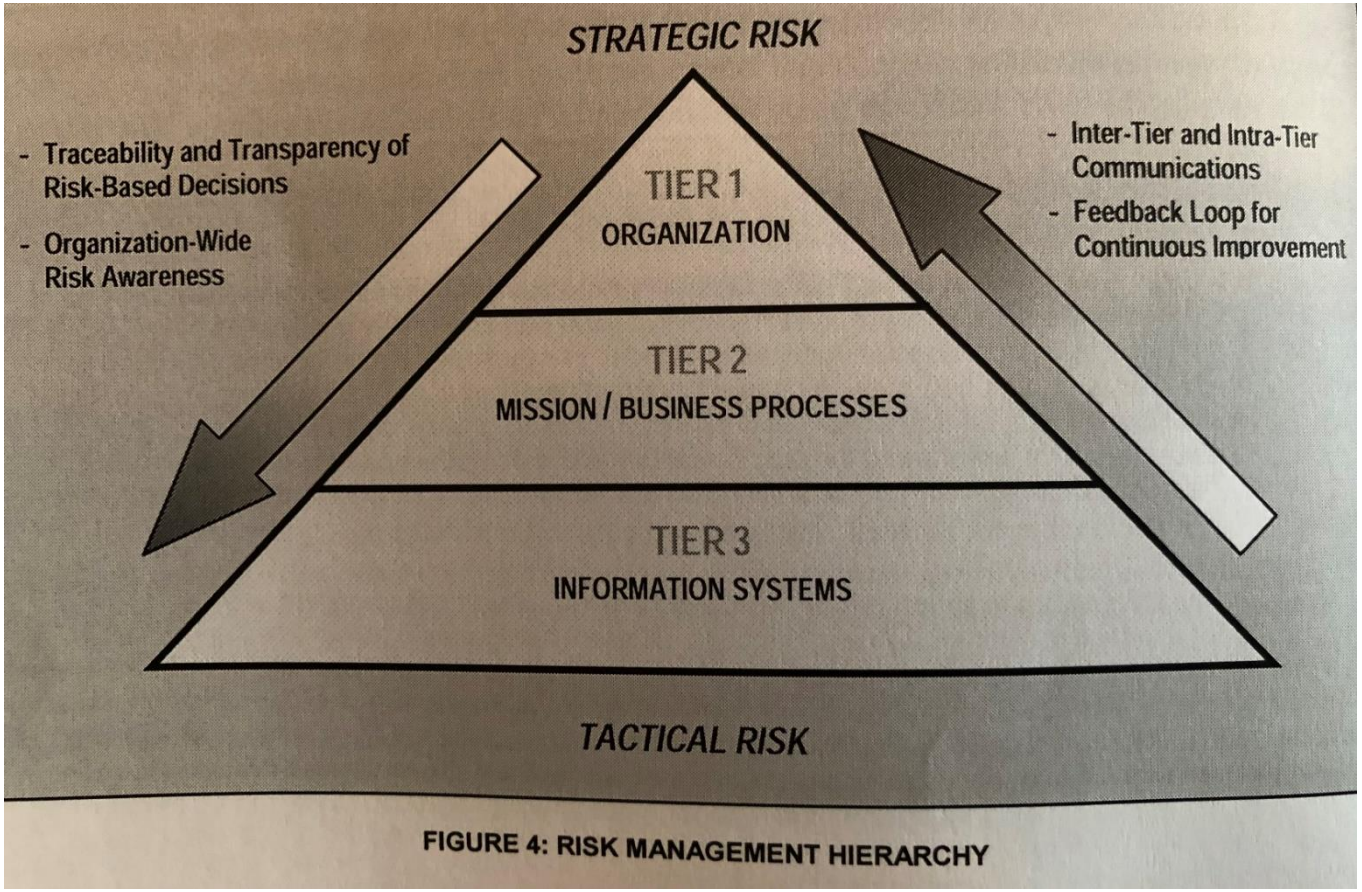


FIGURE 4: RISK MANAGEMENT HIERARCHY

Risk assessment introduction

At Tier 1 and Tier 2

- organizations use risk assessments to evaluate, for example,
  - systemic information security-related risks associated with organizational governance and management activities,
  - mission/business processes, enterprise architecture, or
  - the funding of information security programs.

At Tier 3

- organizations use risk assessments to more effectively support the implementation of the Risk Management Framework
  - (i.e., security categorization; security control selection, implementation, and assessment; information system and common control authorization; and security control monitoring).

NIST SP 800-30, PURPOSE AND APPLICABILITY

- **Purpose:**
  - to provide guidance for conducting risk assessments of federal information systems and organizations, amplifying the guidance in Special Publication 800-39
  - Risk assessments, carried out at all three tiers in the risk management hierarchy, are part of an overall risk management process

    —providing senior leaders/executives with the information needed to determine appropriate courses of action in response to identified risks.

NIST SP 800-30, PURPOSE AND APPLICABILITY

- NIST SP 800-30 provides guidance for carrying out each of the steps in the risk assessment process,
  - preparing for the assessment, conducting the assessment, communicating the results of the assessment, and maintaining the assessment and how risk assessments and other organizational risk management processes complement and inform each other.

Special Publication 800-30 also provides guidance to organizations on identifying specific risk factors to monitor on an ongoing basis, so that organizations can determine whether risks have increased to unacceptable levels (i.e., exceeding organizational risk tolerance) and different courses of action should be taken.

NIST SP 800-30 TARGET AUDIENCE

- Individuals with oversight responsibilities for risk management
  - (e.g., heads of agencies, CEO, COO, risk executive [function]);
- Individuals with responsibilities for conducting organizational missions/business functions
  - (e.g., mission/business owners, information owners/stewards, authorizing officials);
- Individuals with responsibilities for acquiring information technology products, services, or information systems
  - (e.g., acquisition officials, procurement officers, contracting officers);
- Individuals with information system/security design, development, and implementation responsibilities
  - (e.g., program managers, enterprise architects, information security architects, information system/security engineers, information systems integrators);
- Individuals with information security oversight, management, and operational responsibilities
  - (e.g., chief information officers, senior information security officers, information security managers, information system owners, common control providers); and
- Individuals with information security/risk assessment and monitoring responsibilities
  - (e.g., system evaluators, penetration testers, security control assessors, risk assessors, independent verifiers/validators, inspectors general, auditors)

BASIC CONCEPTS ASSOCIATED WITH RISK ASSESSMENTS

CHAPTER 2
THE FUNDAMENTALS

Chapter 2 – The Fundamentals

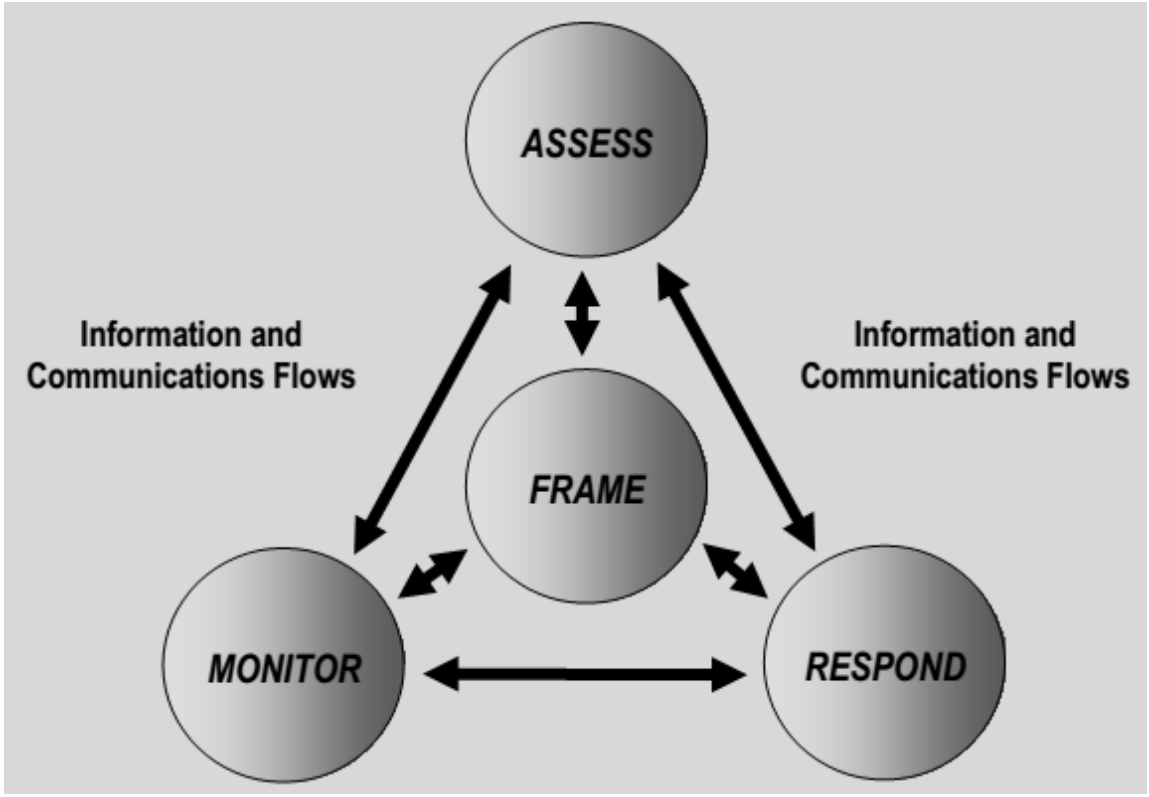
- This section describes the fundamental concepts associated with assessing information security risk within an organization, including:
  - (i) a high-level overview of the risk management process and the role risk assessments play in that process;
  - (ii) the basic concepts used in conducting risk assessments; and
  - (iii) how risk assessments can be applied across the organization's risk management tiers.

RISK MANAGEMENT PROCESS

- Risk management processes include:
  - (i) framing risk - Prepare
  - (ii) assessing risk – Conduct
  - (iii) responding to risk - Communicate
  - (iv) monitoring risk – Maintain

RISK MANAGEMENT PROCESS

- ***FOUR* STEPS** *in the* ***risk management process****—including the risk assessment step and the information and communications flows necessary to make the process work effectively*



RISK MANAGEMENT PROCESS
FRAME RISK

1st component of risk management

addresses how organizations frame risk or establish a risk context—that is, describing the environment in which risk-based decisions are made.

- The **purpose of the risk framing component** is to
  - produce a risk management strategy that addresses how organizations intend to assess risk, respond to risk, and monitor risk—making explicit and transparent the risk perceptions that organizations routinely use in making both investment and operational decisions.
- The risk management strategy establishes a foundation for managing risk and delineates the boundaries for risk-based decisions within organizations.

RISK MANAGEMENT PROCESS
RISK ASSESSMENT

2nd component of risk management

addresses how organizations assess risk within the context of the organizational risk frame.

- The **purpose of the risk assessment component** is to identify:
  - (i) **threats** to organizations (i.e., operations, assets, or individuals) or threats directed through organizations against other organizations or the Nation;
  - (ii) **vulnerabilities** internal and external to organizations;
  - (iii) the **harm** (i.e., adverse **impact**) that may occur given the potential for threats exploiting vulnerabilities; and
  - (iv) the **likelihood** that harm will occur.

The end result is a determination of **risk** (i.e., typically a function of the degree of harm and likelihood of harm occurring).

RISK MANAGEMENT PROCESS
RISK RESPONSE

3rd component of risk management

addresses how organizations respond to risk once that risk is determined based on the results of a risk assessment.

- The **purpose of the risk response component** is to provide a consistent, organization-wide response to risk in accordance with the organizational risk frame by:
  - (i) developing alternative courses of action for responding to risk;
  - (ii) evaluating the alternative courses of action;
  - (iii) determining appropriate courses of action consistent with organizational risk tolerance; and
  - (iv) implementing risk responses based on selected courses of action.
  - + Communicating course of action to stakeholders

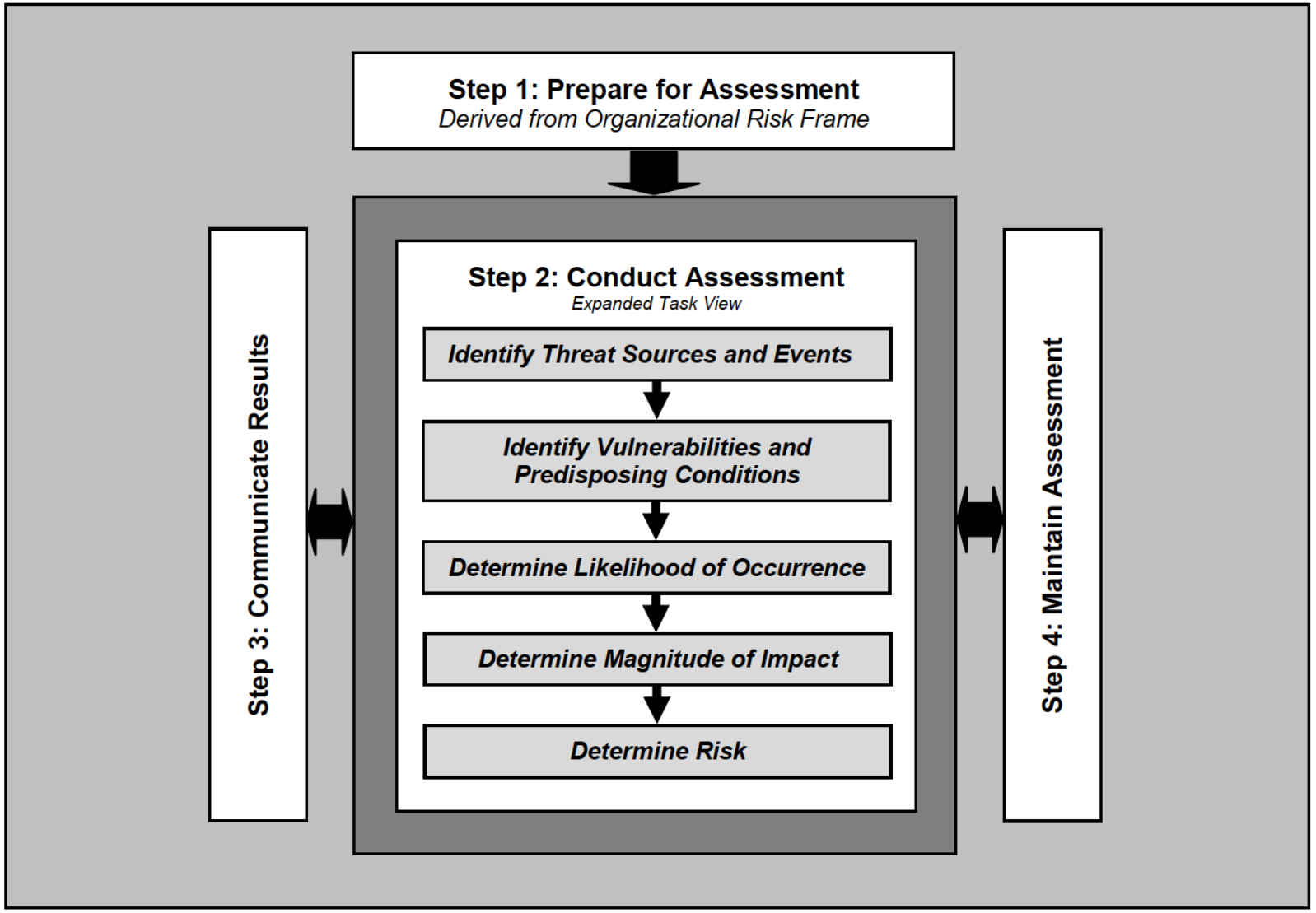
RISK MANAGEMENT PROCESS
RISK MONITOR

4th component of risk management

addresses how organizations monitor risk over time.

- The **purpose of the risk monitoring component** is to:
  - (i) determine the ongoing effectiveness of risk responses (consistent with the organizational risk frame);
  - (ii) identify risk-impacting changes to organizational information systems and the environments in which the systems operate; and
  - (iii) verify that planned risk responses are implemented and information security requirements derived from and traceable to organizational missions/business functions, federal legislation, directives, regulations, policies, standards, and guidelines are satisfied.

CHAPTER 3: THE PROCESS



NIST 800-30: ACT

- **Risk Response Options**
- **Mitigate:** Apply security controls to lower risk.
- **Transfer:** Share risk through insurance or contracts.
- **Avoid:** Stop the risky activity.
- **Accept:** Choose to live with the residual risk based on business needs.

NIST 800-30: ACT

Mitigation

- **Control recommendations and risk documentation**
- The final control recommendations using the NIST SP 800-53 standard are proposed (next), and a risk assessment report is prepared from earlier documented results. Control recommendations could pertain either to reducing the likelihood of a threat, or to mitigation of impact to reduce the risk score.

NIST Special Publication 800-53
Revision 5

Security and Privacy Controls for Information Systems and Organizations

JOINT TASK FORCE

This publication is available free of charge from:
https://doi.org/10.6028/NIST.SP.800-53r5

September 2020
INCLUDES UPDATES AS OF 12-10-2020; SEE PAGE XVII



The NIST list of security controls

CHAPTER THREE THE CONTROLS 16

3.1 ACCESS CONTROL 18
3.2 AWARENESS AND TRAINING 59
3.3 AUDIT AND ACCOUNTABILITY 65
3.4 ASSESSMENT, AUTHORIZATION, AND MONITORING 83
3.5 CONFIGURATION MANAGEMENT 96
3.6 CONTINGENCY PLANNING 115
3.7 IDENTIFICATION AND AUTHENTICATION 131
3.8 INCIDENT RESPONSE 149
3.9 MAINTENANCE 162
3.10 MEDIA PROTECTION 171
3.11 PHYSICAL AND ENVIRONMENTAL PROTECTION 179
3.12 PLANNING 194
3.13 PROGRAM MANAGEMENT 203
3.14 PERSONNEL SECURITY 222
3.15 PERSONALLY IDENTIFIABLE INFORMATION PROCESSING AND TRANSPARENCY 229
3.16 RISK ASSESSMENT 238
3.17 SYSTEM AND SERVICES ACQUISITION 249
3.18 SYSTEM AND COMMUNICATIONS PROTECTION 292
3.19 SYSTEM AND INFORMATION INTEGRITY 332
3.20 SUPPLY CHAIN RISK MANAGEMENT 363

NIST Special Publication 800-37
Revision 2

Risk Management Framework for Information Systems and Organizations

A System Life Cycle Approach for Security and Privacy

JOINT TASK FORCE

This publication is available free of charge from:
https://doi.org/10.6028/NIST.SP.800-37r2

December 2018

Purpose

The Risk Management Framework (RMF) provides a disciplined, structured, and flexible process for managing security and privacy risk that includes information security categorization; control selection, implementation, and assessment; system and common control authorizations; and continuous monitoring. *(like 27005…)*

The goals of the US Government

As we push computers to “the edge,” building a complex world of interconnected information systems and devices, security and privacy risks (including supply chain risks) continue to be a large part of the national conversation and topics of great importance… There is an urgent need to further strengthen the underlying information systems, component products, and services that we depend on in every sector of the critical infrastructure—ensuring that the systems, products, and services are sufficiently trustworthy throughout the system development life cycle (SDLC) and can provide the necessary resilience to support the economic and national security interests of the United States. System modernization, the increased use of automation, and the consolidation, standardization, and optimization of federal systems and networks to strengthen the protection for high value assets, are key objectives for the federal government.

The steps of the risk management framework



1.a PREPARE tasks and outcomes – organizational level

Tasks	Outcomes
TASK P-1 RISK MANAGEMENT ROLES	• Individuals are identified and assigned key roles for executing the Risk Management Framework. [*Cybersecurity Framework*: **ID.AM-6**; **ID.GV-2**]
TASK P-2 RISK MANAGEMENT STRATEGY	• A risk management strategy for the organization that includes a determination and expression of organizational risk tolerance is established. [*Cybersecurity Framework*: **ID.RM; ID.SC**]
TASK P-3 RISK ASSESSMENT—ORGANIZATION	• An organization-wide risk assessment is completed or an existing risk assessment is updated. [*Cybersecurity Framework*: **ID.RA; ID.SC-2**]
TASK P-4 ORGANIZATIONALLY-TAILORED CONTROL BASELINES AND CYBERSECURITY FRAMEWORK PROFILES (OPTIONAL)	• Organizationally-tailored control baselines and/or Cybersecurity Framework Profiles are established and made available. [*Cybersecurity Framework*: **Profile**]
TASK P-5 COMMON CONTROL IDENTIFICATION	• Common controls that are available for inheritance by organizational systems are identified, documented, and published.
TASK P-6 IMPACT-LEVEL PRIORITIZATION (OPTIONAL)	• A prioritization of organizational systems with the same impact level is conducted. [*Cybersecurity Framework*: **ID.AM-5**]
TASK P-7 CONTINUOUS MONITORING STRATEGY—ORGANIZATION	• An organization-wide strategy for monitoring control effectiveness is developed and implemented. [*Cybersecurity Framework*: **DE.CM; ID.SC-4**]

1.b PREPARE tasks and outcomes – system level

Tasks	Outcomes
TASK P-8 MISSION OR BUSINESS FOCUS	• Missions, business functions, and mission/business processes that the system is intended to support are identified. [*Cybersecurity Framework*: **Profile**; **Implementation Tiers**; **ID.BE**]
TASK P-9 SYSTEM STAKEHOLDERS	• The stakeholders having an interest in the system are identified. [*Cybersecurity Framework*: **ID.AM**; **ID.BE**]
TASK P-10 ASSET IDENTIFICATION	• Stakeholder assets are identified and prioritized. [*Cybersecurity Framework*: **ID.AM**]
TASK P-11 AUTHORIZATION BOUNDARY	• The authorization boundary (i.e., system) is determined.
TASK P-12 INFORMATION TYPES	• The types of information processed, stored, and transmitted by the system are identified. [*Cybersecurity Framework*: **ID.AM-5**]
TASK P-13 INFORMATION LIFE CYCLE	• All stages of the information life cycle are identified and understood for each information type processed, stored, or transmitted by the system. [*Cybersecurity Framework*: **ID.AM-3**; **ID.AM-4**]
TASK P-14 RISK ASSESSMENT—SYSTEM	• A system-level risk assessment is completed or an existing risk assessment is updated. [*Cybersecurity Framework*: **ID.RA; ID.SC-2**]
TASK P-15 REQUIREMENTS DEFINITION	• Security and privacy requirements are defined and prioritized. [*Cybersecurity Framework*: **ID.GV; PR.IP**]
TASK P-16 ENTERPRISE ARCHITECTURE	• The placement of the system within the enterprise architecture is determined.
TASK P-17 REQUIREMENTS ALLOCATION	• Security and privacy requirements are allocated to the system and to the environment in which the system operates. [*Cybersecurity Framework*: **ID.GV**]
TASK P-18 SYSTEM REGISTRATION	• The system is registered for purposes of management, accountability, coordination, and oversight. [*Cybersecurity Framework*: **ID.GV**]

2. CATEGORIZE tasks and outcomes

Tasks	Outcomes
TASK C-1 SYSTEM DESCRIPTION	• The characteristics of the system are described and documented. [*Cybersecurity Framework*: **Profile**]
TASK C-2 SECURITY CATEGORIZATION	• A security categorization of the system, including the information processed by the system represented by the organization-identified information types, is completed. [*Cybersecurity Framework*: **ID.AM-1**; **ID.AM-2**; **ID.AM-3**; **ID.AM-4**; **ID.AM-5**] • Security categorization results are documented in the security, privacy, and SCRM plans. [*Cybersecurity Framework*: **Profile**] • Security categorization results are consistent with the enterprise architecture and commitment to protecting organizational missions, business functions, and mission/business processes. [*Cybersecurity Framework*: **Profile**] • Security categorization results reflect the organization's risk management strategy.
TASK C-3 SECURITY CATEGORIZATION REVIEW AND APPROVAL	• The security categorization results are reviewed and the categorization decision is approved by senior leaders in the organization.

3. SELECT tasks and outcomes

Tasks	Outcomes
TASK S-1 CONTROL SELECTION	• Control baselines necessary to protect the system commensurate with risk are selected. [*Cybersecurity Framework*: **Profile**]
TASK S-2 CONTROL TAILORING	• Controls are tailored producing tailored control baselines. [*Cybersecurity Framework*: **Profile**]
TASK S-3 CONTROL ALLOCATION	• Controls are designated as system-specific, hybrid, or common controls. • Controls are allocated to the specific system elements (i.e., machine, physical, or human elements). [*Cybersecurity Framework*: **Profile**; **PR.IP**]
TASK S-4 DOCUMENTATION OF PLANNED CONTROL IMPLEMENTATIONS	• Controls and associated tailoring actions are documented in security and privacy plans or equivalent documents. [*Cybersecurity Framework*: **Profile**]
TASK S-5 CONTINUOUS MONITORING STRATEGY—SYSTEM	• A continuous monitoring strategy for the system that reflects the organizational risk management strategy is developed. [*Cybersecurity Framework*: **ID.GV**; **DE.CM**]
TASK S-6 PLAN REVIEW AND APPROVAL	• Security and privacy plans reflecting the selection of controls necessary to protect the system and the environment of operation commensurate with risk are reviewed and approved by the authorizing official.

4. IMPLEMENT tasks and outcome

Tasks	Outcomes
TASK I-1 CONTROL IMPLEMENTATION	• Controls specified in the security and privacy plans are implemented. [*Cybersecurity Framework*: **PR.IP-1**] • Systems security and privacy engineering methodologies are used to implement the controls in the system security and privacy plans. [*Cybersecurity Framework*: **PR.IP-2**]
TASK I-2 UPDATE CONTROL IMPLEMENTATION INFORMATION	• Changes to the planned implementation of controls are documented. [*Cybersecurity Framework*: **PR.IP-1**] • The security and privacy plans are updated based on information obtained during the implementation of the controls. [*Cybersecurity Framework*: **Profile**]

5. Assess tasks and outcomes

Tasks	Outcomes
TASK A-1 ASSESSOR SELECTION	• An assessor or assessment team is selected to conduct the control assessments. • The appropriate level of independence is achieved for the assessor or assessment team selected.
TASK A-2 ASSESSMENT PLAN	• Documentation needed to conduct the assessments is provided to the assessor or assessment team. • Security and privacy assessment plans are developed and documented. • Security and privacy assessment plans are reviewed and approved to establish the expectations for the control assessments and the level of effort required.
TASK A-3 CONTROL ASSESSMENTS	• Control assessments are conducted in accordance with the security and privacy assessment plans. • Opportunities to reuse assessment results from previous assessments to make the risk management process timely and cost-effective are considered. • Use of automation to conduct control assessments is maximized to increase speed, effectiveness, and efficiency of assessments.
TASK A-4 ASSESSMENT REPORTS	• Security and privacy assessment reports that provide findings and recommendations are completed.
TASK A-5 REMEDIATION ACTIONS	• Remediation actions to address deficiencies in the controls implemented in the system and environment of operation are taken. • Security and privacy plans are updated to reflect control implementation changes made based on the assessments and subsequent remediation actions. [*Cybersecurity Framework*: **Profile**]
TASK A-6 PLAN OF ACTION AND MILESTONES	• A plan of action and milestones detailing remediation plans for unacceptable risks identified in security and privacy assessment reports is developed. [*Cybersecurity Framework*: **ID.RA-6**]

6. Authorize

Tasks	Outcomes
TASK R-1 AUTHORIZATION PACKAGE	• An authorization package is developed for submission to the authorizing official.
TASK R-2 RISK ANALYSIS AND DETERMINATION	• A risk determination by the authorizing official that reflects the risk management strategy including risk tolerance, is rendered.
TASK R-3 RISK RESPONSE	• Risk responses for determined risks are provided. [*Cybersecurity Framework*: **ID.RA-6**]
TASK R-4 AUTHORIZATION DECISION	• The authorization for the system or the common controls is approved or denied.
TASK R-5 AUTHORIZATION REPORTING	• Authorization decisions, significant vulnerabilities, and risks are reported to organizational officials.

7. MONITOR

Tasks	Outcomes
TASK M-1 SYSTEM AND ENVIRONMENT CHANGES	• The information system and environment of operation are monitored in accordance with the continuous monitoring strategy. [*Cybersecurity Framework*: **DE.CM**; **ID.GV**]
TASK M-2 ONGOING ASSESSMENTS	• Ongoing assessments of control effectiveness are conducted in accordance with the continuous monitoring strategy. [*Cybersecurity Framework*: **ID.SC-4**]
TASK M-3 ONGOING RISK RESPONSE	• The output of continuous monitoring activities is analyzed and responded to appropriately. [*Cybersecurity Framework*: **RS.AN**]
TASK M-4 AUTHORIZATION PACKAGE UPDATES	• Risk management documents are updated based on continuous monitoring activities. [*Cybersecurity Framework*: **RS.IM**]
TASK M-5 SECURITY AND PRIVACY REPORTING	• A process is in place to report the security and privacy posture to the authorizing official and other senior leaders and executives.
TASK M-6 ONGOING AUTHORIZATION	• Authorizing officials conduct ongoing authorizations using the results of continuous monitoring activities and communicate changes in risk determination and acceptance decisions.
TASK M-7 SYSTEM DISPOSAL	• A system disposal strategy is developed and implemented, as needed.

Tasks, responsibilities and supporting roles

RMF TASKS	PRIMARY RESPONSIBILITY	SUPPORTING ROLES
Organization Level		
TASK P-1 **Risk Management Roles** Identify and assign individuals to specific roles associated with security and privacy risk management.	• Head of Agency • Chief Information Officer • Senior Agency Official for Privacy	• Authorizing Official or Authorizing Official Designated Representative • Senior Accountable Official for Risk Management or Risk Executive (Function) • Senior Agency Information Security Officer
TASK P-2 **Risk Management Strategy** Establish a risk management strategy for the organization that includes a determination of risk tolerance.	• Head of Agency	• Senior Accountable Official for Risk Management or Risk Executive (Function) • Chief Information Officer • Senior Agency Information Security Officer • Senior Agency Official for Privacy
TASK P-3 **Risk Assessment—Organization** Assess organization-wide security and privacy risk and update the risk assessment results on an ongoing basis.	• Senior Accountable Official for Risk Management or Risk Executive (Function) • Senior Agency Information Security Officer • Senior Agency Official for Privacy	• Chief Information Officer • Authorizing Official or Authorizing Official Designated Representative • Mission or Business Owner
TASK P-4 **Organizationally-Tailored Control Baselines and Cybersecurity Framework Profiles (Optional)** Establish, document, and publish organizationally-tailored control baselines and/or Cybersecurity Framework Profiles.	• Mission or Business Owner • Senior Accountable Official for Risk Management or Risk Executive (Function)	• Chief Information Officer • Authorizing Official or Authorizing Official Designated Representative • Senior Agency Information Security Officer • Senior Agency Official for Privacy

Thank you!

For information:

Indirizzo e-mail

cybersecurity_info@uniroma1.it
Stefano.zatti@uniroma1.it

Sito Web

https://cybersecurity.uniroma1.it

Link to google drive:

https://drive.google.com/drive/folders/15-hLIVz4aEroHWc8dkSBqa995iZSJOuT